



Weekly Project Progress 3: Threat Model

FINTECH 512 - Software Engineering for FinTech

Full team of five members for the group project (section 1)



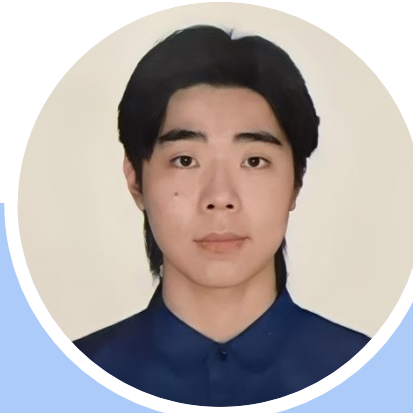
Rebeca Hechtman
NetId: rh398



Mike Lin
NetId: hl561



Mory Shi
NetId: cs836



Loki Luo
NetId: lz294



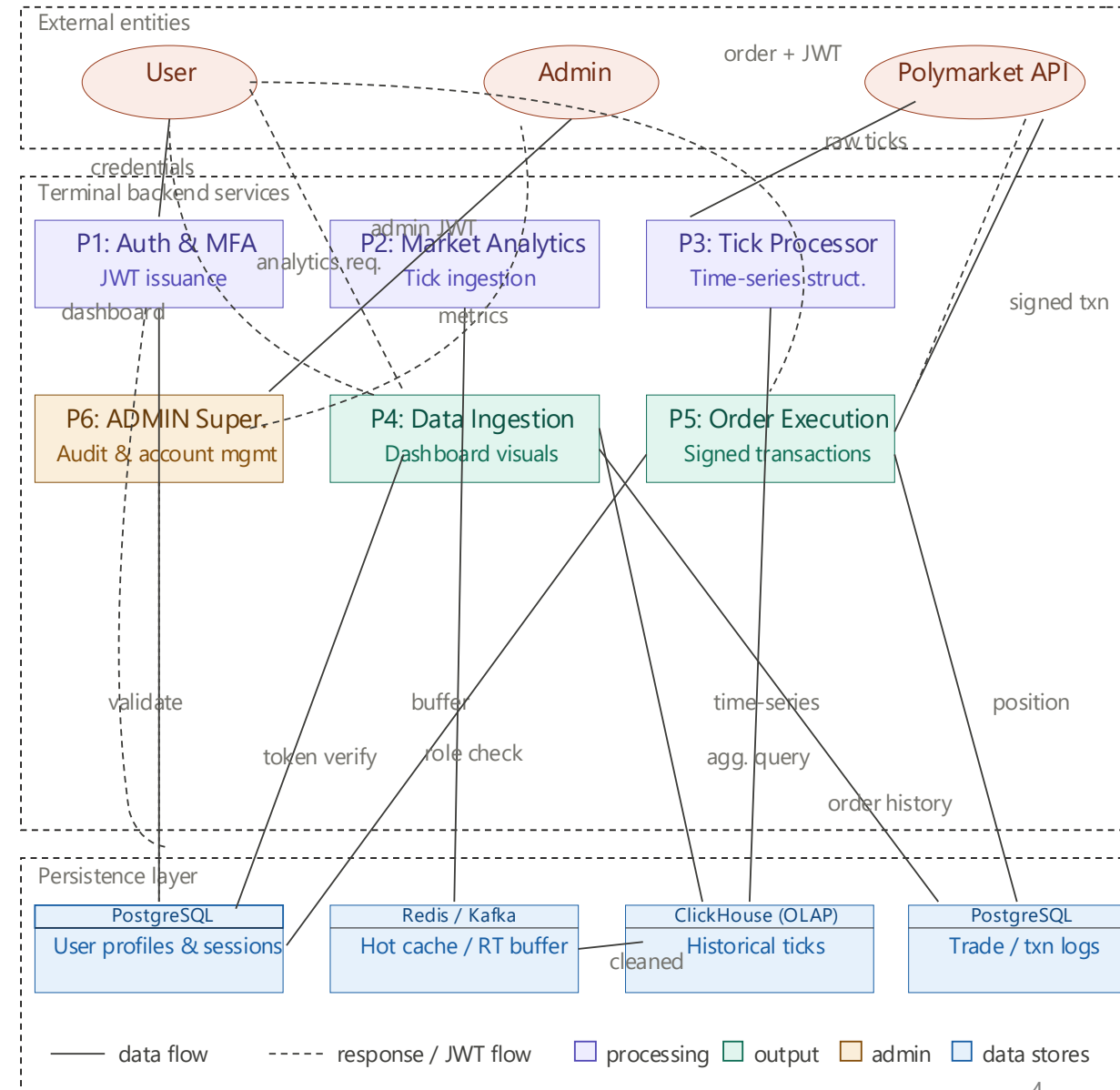
Alan Song
NetId: ys501

Threat Model

Data Flow Diagram (DFD)

System Overview:

- Users interact with the system through frontend connected to backend APIs
 - Backend services process authentication, logics and provide database access
 - External market data – Polymarket is ingested, processed and stored
 - Data views as dashboards and analytics components.
-
- **Assets:** User credentials and OAuth tokens, user permissions, Orderbook data and trade records, market structure data, internal APIs and service endpoints, PostgreSQL database contents, external market data (Polymarket based), system logs, audit records.
 - **Actors:** User, Administrator, Polymarket API, Backend Services (for handling logics and data processing)
 - **Threats:** Based on STRIDE analysis



Data Flow Diagram (DFD) – STRIDE analysis, threat and mitigation

All S T R I D E

CATEGORY	SEV.	NODES	THREAT	MITIGATION
Spoofing	H	User P1	JWT/session token stolen & replayed	Short-lived tokens + revocation list in D1
Spoofing	H	PoLyAPI P2	Polymarket API spoofed, fake tick data injected	TLS cert pinning + HMAC signature on every feed
Tampering	H	P5 PoLyAPI	Order request tampered before signing	User-signed payload; P5 verifies hash against receipt
Tampering	H	P2 D2	Tick data corrupted in Redis/Kafka buffer	Per-message checksum; P3 validates before writing D3
Repudiation	H	P5 D4	User denies placing order — no audit trail	Append-only signed order log in D4
Repudiation	M	P6 D1	Admin denies executing command	Immutable admin audit log; ship to off-system SIEM
Info disclosure	H	D1 P1	User PII leaked via errors or SQL injection	Parameterised queries; encrypt PII columns; no stack traces
Info disclosure	H	P6 PoLyAPI	API keys exposed via overexposed admin endpoint	P6 behind VPN/allowlist; secrets manager for all keys
Denial of service	H	P2 D2 P3	Tick flood overwhelms data pipeline	Rate-limit at P2; back-pressure on Kafka; circuit breaker
Denial of service	M	P4 D3	Expensive analytics queries degrade OLAP store	Per-user query budget + result caching in P4
Elevation of priv.	H	P6 P4 P5	Regular user JWT accepted on admin P6 endpoints	Deny-by-default middleware; role validated on every request
Elevation of priv.	H	P5 D1	JWT role claim tampered to bypass order checks	RS256 signing; re-fetch authoritative role from D1

STRIDE analysis:

- Spoofing
 - Stolen session or OAuth token, external data source is not true.
- Tampering
 - Modified API requests, data corruption and wrong market data.
- Repudiation
 - Users/admin deny actions, missing logs for audit.
- Information disclosure:
 - Data leakage like user information and API keys, and overexposed admin endpoints.
- Denial of service
 - Data pipeline overload.
- Elevation of privilege:
 - Users access admins endpoints, and lack of authorization check.

Data Flow Diagram (DFD) - Team Discussion

'What are we working on?'

Can we see where all the data goes and who uses it?

- Yes, we can see all the data goes and the actors by nodes connections, and comments between those node represent the relations.
- The entities interact with which endpoints are clear.

Do we see the processes that move data from one data store to another?

- Yes, the diagram shows exactly how backend processes data in transit.
- For example, the Tick processor (P3) taking buffered data from Redis/Kafka and moves TS structure to Clickhouse OLAP store.

Does the diagram show all the trust boundaries, such as where different accounts interact?

- Yes, the bounding box separates boundaries by "External Entities", "Terminal backend Services", and "Persistence Layer".

Can we look at the diagram and see exactly where the software will make a security decision?

- Yes, a security decision will be made by Auth & MFA (P1), and Admin Super (P6) as authentication decisions and authorized role checking processes run.

Does the diagram reflect the current or planned reality of the software?

- Yes, the software is well-defined by DFD.
- Including specific database including PostgreSQL, ClickHouse, Redit, and external API (Polymarket).

'What can go wrong?'

Have we looked at each element of the diagram?

- Yes, we have fully reviewed the API gateways, the internal backend processes from P1 to P6 and the data storages.

Have we looked for each of the STRIDE threats?

- Yes, we have fully reviewed each threat by STRIDE analysis, by that two vulnerabilities for every single category are being checked.

For each threat, can we describe the actor, the attack, and the impact?

- Yes, we table has defined the nodes involved, with severity (High/Median), and the nature of attack such as stealing a JWT token or attacker flooding within the pipeline.

'What are we going to do about it?'

Is there a proposed/planned/implemented mitigation to address each threat?

- Yes, we have mitigations for each threat based on STRIDE and also included in the table.

Are there test cases we should write?

- Testing our API endpoints for SQL injection vulnerabilities.
- Simulating tick data floods to ensure P2 rate, which limiting and Kafka back-pressure hold up.
- Attempting to access P6 administration endpoints with regular user JWTs to verify our deny-by-default middleware.

Thank you!